

Checklist

Network Segmentation Security

Network Design

- ☐ Identify systems, users, applications, and data that require segmentation.
- ☐ Document the network topology and existing trust boundaries.
- ☐ Separate systems according to risk, function, sensitivity, and business need.
- ☐ Apply the principle of least privilege between all network segments.
- ☐ Use a **default-deny/allow-list** approach wherever practical.
- ☐ Document approved traffic flows between segments.
- ☐ Regularly review segmentation rules and remove unnecessary access.

Physical Segmentation

- ☐ Use firewalls, routers, and switches to create security boundaries.
- ☐ Configure firewall rules specifically for the needs of each segment.
- ☐ Monitor traffic crossing network boundaries.
- ☐ Ensure network devices provide adequate logging.
- ☐ Separate development/test networks from production.
- ☐ Separate networks containing sensitive or regulated data.
- ☐ Place internet-facing systems in a DMZ.
- ☐ Separate guest networks from internal corporate networks.
- ☐ Limit unnecessary outbound/egress internet access.
- ☐ Reduce unnecessary broadcast traffic.

DMZ

- ☐ Place public-facing servers in a dedicated DMZ.
- ☐ Configure the DMZ firewall to deny traffic by default.

- ☐ Allow only required inbound ports and services.
- ☐ Restrict traffic from the DMZ to the internal network.
- ☐ Prevent unrestricted communication between DMZ systems and trusted systems.
- ☐ Monitor DMZ systems closely because they are exposed to higher risk.

VLANs

- ☐ Group endpoints into VLANs based on security requirements.
- ☐ Separate high-priority servers, standard servers, user endpoints, and other device categories as needed.
- ☐ Use ACLs or firewall policies to control traffic between VLANs.
- ☐ Configure only necessary VLANs on each physical switch.
- ☐ Disable or restrict unused VLAN access.
- ☐ Protect against VLAN-hopping and related attacks.
- ☐ Do not rely on VLANs as the only segmentation security control.
- ☐ Document VLAN IDs, purposes, permitted traffic, and assigned devices.

Access Control Lists (ACLs)

- ☐ Apply ACLs between subnets or network segments.
- ☐ Create specific rules based on source address, destination address, port, and protocol.
- ☐ Avoid overly broad **ANY-ANY** allow rules.
- ☐ Include an explicit deny rule at the end of the ACL where appropriate.
- ☐ Log denied or dropped traffic when useful for monitoring.
- ☐ Review ACLs regularly for obsolete or unnecessary rules.
- ☐ Test ACL changes before applying them to production systems.

Network Access Control (NAC)

- ☐ Require authentication before devices receive normal network access.
- ☐ Use 802.1X where appropriate.
- ☐ Validate device security posture before granting access.
- ☐ Place unknown or noncompliant devices in an isolated network.
- ☐ Scan new third-party or vendor equipment before production access.
- ☐ Use guest captive portals for visitor access where appropriate.
- ☐ Restrict guest networks to required services, typically internet access only.
- ☐ Apply NAC controls in conference rooms and other shared connection areas.

- ☐ Integrate NAC with BYOD policies.
- ☐ Deny unauthorized or unmanaged devices when required.

VPN Security

- ☐ Use the strongest practical authentication method.
- ☐ Use strong, current encryption methods.
- ☐ Grant VPN access only for a valid business need.
- ☐ Remove VPN access when it is no longer required.
- ☐ Limit remote users to only the resources they need.
- ☐ Apply endpoint or host-integrity checks where supported.
- ☐ Integrate VPN authentication with centralized identity services where appropriate.
- ☐ Log and audit VPN activity.
- ☐ Carefully evaluate split tunneling before enabling it.
- ☐ Protect browser-based VPN sessions against credential theft and malware exposure.
- ☐ Use secure IPsec or SSL/TLS configurations appropriate to the environment.

Egress Traffic

- ☐ Determine which systems actually require internet access.
- ☐ Block direct internet access for servers that do not need it.
- ☐ Use internal repositories for software and updates when practical.
- ☐ Restrict outbound traffic by destination, port, and protocol.
- ☐ Monitor unusual outbound connections.

Application Segmentation

- ☐ Separate application components when the security benefit justifies it.
- ☐ Separate web servers from database servers.
- ☐ Restrict database access to authorized application systems.
- ☐ Prevent unnecessary direct access to raw database files.
- ☐ Store SSL/TLS private keys away from public-facing web servers when possible.
- ☐ Use reverse proxies, load balancers, or dedicated security devices where appropriate.
- ☐ Restrict communication between application tiers to required ports and protocols.

- ☐ Apply segmentation especially to applications processing sensitive data.

Software-Defined Networking (SDN)

- ☐ Evaluate whether SDN or microsegmentation can improve network isolation.
- ☐ Secure the SDN control plane.
- ☐ Restrict administrative access to SDN controllers.
- ☐ Monitor automated network policy changes.
- ☐ Maintain accurate documentation of software-defined network rules.
- ☐ Verify that removing traditional network devices does not eliminate necessary security controls.

Roles and Responsibilities

- ☐ Separate development and production responsibilities where possible.
- ☐ Prevent developers from having unnecessary direct production access.
- ☐ Separate transaction creation from transaction approval responsibilities.
- ☐ Use role-based access control (RBAC).
- ☐ Review user and administrator permissions regularly.
- ☐ Disable generic administrative accounts where possible.
- ☐ Alert on use of generic or shared privileged accounts.
- ☐ Give database administrators only the privileges needed for database administration.
- ☐ Avoid giving unnecessary operating-system root or administrator privileges.
- ☐ Provide administrators with separate standard and privileged accounts.
- ☐ Use standard accounts for routine activities such as email and browsing.
- ☐ Use privileged accounts only for administrative tasks.
- ☐ Consider separate administrative workstations for privileged activity.
- ☐ Clearly identify authorized backup administrators and document procedures.

Server and Service Separation

- ☐ Avoid combining unrelated critical services on the same server.
- ☐ Separate databases from application servers when risk warrants it.
- ☐ Keep especially sensitive server roles isolated.
- ☐ Isolate Active Directory/domain controllers from unnecessary services.
- ☐ Isolate mail servers where appropriate.
- ☐ Isolate systems storing personally identifiable information (PII).

Sensitive and Regulated Data

- ☐ Identify where sensitive information is stored.
- ☐ Create dedicated security zones for sensitive data.
- ☐ Restrict access according to business need.
- ☐ Apply additional monitoring around sensitive-data segments.
- ☐ Verify segmentation requirements for applicable standards such as PCI DSS or HIPAA.
- ☐ Document how segmentation supports regulatory compliance.

Monitoring and Maintenance

- ☐ Capture or analyze network traffic where appropriate.
- ☐ Use network-flow analysis to identify abnormal communication.
- ☐ Log permitted and denied traffic at important security boundaries.
- ☐ Regularly review firewall, VLAN, ACL, NAC, and VPN configurations.
- ☐ Test segmentation controls to verify that prohibited traffic is actually blocked.
- ☐ Keep network diagrams and documentation current.
- ☐ Apply consistent naming conventions to devices, rules, VLANs, and security zones.
- ☐ Remove obsolete devices, rules, accounts, and configurations.
- ☐ Reassess segmentation whenever systems, applications, or business requirements change.

Final Review

- ☐ Can each segment communicate only with systems it legitimately needs?
- ☐ Are sensitive systems separated from lower-trust systems?
- ☐ Is lateral movement between segments minimized?
- ☐ Are unnecessary inbound and outbound connections blocked?
- ☐ Are segmentation controls monitored and logged?
- ☐ Can administrators quickly understand and troubleshoot the design?
- ☐ Does the design balance security with legitimate usability and business requirements?

